TaskFlow Software – Ransomware Incident Response Playbook

Playbook ID: IR-PB-002
Incident Type: Ransomware Attack
Severity: Critical
Primary Owner: SOC Analyst
Environment: TaskFlow Software SaaS Beta
Status: Draft – Pending Tabletop Validation

1. Purpose

This playbook provides procedures for identifying, containing, investigating, and recovering from ransomware incidents affecting TaskFlow Software.

The objective is to prevent ransomware propagation, protect sensitive customer data, preserve evidence, and restore critical services safely.

2. Affected Assets

Asset ID	Asset Name	Risk Level
TF-003	Customer Database	Critical
TF-001	Web Application	Critical
TF-002	REST API	Critical
TF-005	CI/CD Pipeline	High
TF-006	Source Code Repository	High
TF-007	Logging and Monitoring System	High

Primary risk: Ransomware may encrypt important business data, disrupt SaaS operations, and expose sensitive information.

3. Detection and Identification

Responsible: SOC Analyst

1. Review suspicious security events in Elastic Security/Kibana.
2. Investigate unusual file modifications, encryption activity, or unexpected service failures.
3. Examine available system and application logs for suspicious processes or unauthorized access.
4. Correlate event timestamps, source IP addresses, and affected assets.
5. Determine whether ransomware activity is suspected or confirmed.
6. Preserve relevant logs, alert IDs, and other available evidence.

Detection sources: Elastic Security monitoring, available system logs, and incident reports.

4. Incident Response Procedures

Phase 1 – Preparation

Responsible: SOC Analyst / System Administrator

- Review critical assets and their risk ratings in `assets.json`.
- Verify backup availability and recovery procedures.
- Confirm incident escalation contacts and isolation procedures.
- Ensure logging and monitoring are functioning.

Phase 2 – Analysis and Classification

Responsible: SOC Analyst

- Identify potentially infected systems and affected services.
- Investigate suspicious processes and signs of unauthorized encryption.
- Determine whether customer data or production services are affected.
- Record the incident timeline and indicators of compromise.
- Escalate confirmed ransomware activity as a critical incident.

Phase 3 – Containment

Responsible: System Administrator / SOC Analyst

- Isolate affected hosts or workloads from the network using approved procedures.
- Restrict compromised accounts and revoke exposed credentials.
- Temporarily disable affected services when necessary and authorized.
- Protect unaffected backup systems from possible compromise.

- Preserve forensic evidence where feasible before destructive actions.

Phase 4 – Eradication

Responsible: System Administrator

- Identify and remove the ransomware infection through verified remediation procedures.
- Investigate the initial access method and potential persistence mechanisms.
- Patch exploited vulnerabilities and correct insecure configurations.
- Rebuild compromised systems from trusted images when required.
- Verify that malicious activity has stopped before recovery.

Phase 5 – Recovery

Responsible: System Administrator / SOC Analyst

- Restore affected systems from verified clean backups.
- Validate the integrity of restored customer and application data.
- Test the Web Application, REST API, and Authentication Service.
- Reconnect recovered systems in a controlled manner.
- Monitor Elastic Security for recurring suspicious activity.
- Obtain approval before returning critical services to normal operation.

Phase 6 – Lessons Learned

Responsible: SOC Analyst / Incident Owner

- Document the root cause, response timeline, and business impact.
- Evaluate the effectiveness of isolation and recovery procedures.
- Identify backup, monitoring, and access-control weaknesses.
- Update ransomware response procedures and security controls.

5. Escalation and Responsibilities

Role	Responsibility
SOC Analyst	Investigate alerts, preserve evidence, coordinate response
System Administrator	Isolate systems, remove threats, restore services
Management / Incident Owner	Approve disruptive actions and coordinate business decisions
Application Owner	Validate application functionality and restored data

In TaskFlow's single-analyst environment, the SOC Analyst coordinates technical and management escalation.

6. Closure Criteria

The incident may be closed when:

- Compromised systems have been isolated, cleaned, or rebuilt.
- Critical services have been restored and validated.
- Restored data integrity has been verified.
- Monitoring shows no continuing related malicious activity.
- Evidence, response actions, and improvement items are documented.
- The incident owner approves closure.

References: `assets.json`, Elastic Security dashboard, incident monitoring logs.

Note: This document defines proposed response procedures. Actual containment and recovery actions must be authorized and will be evaluated through the tabletop exercise.